Brooklyn Nine-Nine CTF — Walkthrough

Lab / CTF Report

Overview

This report documents the exploitation of the Brooklyn Nine-Nine CTF machine, covering initial access via anonymous FTP and privilege escalation to root using the GTFOBins technique for the 'less' binary.

Attack Path Summary

- Enumeration — discovered an FTP service allowing anonymous login.
- Initial Access — logged into FTP anonymously and retrieved files/credentials leading to a foothold.
- Privilege Escalation — identified sudo rights on the 'less' binary and abused it via GTFOBins to spawn a root shell.

1. Initial Access — Anonymous FTP

The target exposed an FTP service that permitted anonymous authentication. This is a common misconfiguration where the server accepts a blank or 'anonymous' username with any password, granting access to the FTP share without valid credentials.

Example commands:

```
ftp <target-ip>
Name: anonymous
Password: (blank or anonymous)
ftp> ls
ftp> get <file>
```

Files retrieved from the share were used to enumerate further and obtain a foothold on the system.

2. Privilege Escalation — GTFOBins 'less'

Enumeration of sudo permissions (via 'sudo -l') revealed that the compromised user could run 'less' with elevated privileges. The 'less' pager can be abused to spawn an interactive shell from within its command prompt, inheriting the privilege level it was run with.

Exploitation steps:

```
sudo -l
  # (User may run: /usr/bin/less)

sudo less <any-file>
  # Inside the less pager, type:
!/bin/sh

# Resulting shell runs with the privileges less was executed as (root)
```

This confirms the classic GTFOBins escape: 'less' allows shell command execution via '!', and when invoked through sudo, the spawned shell inherits root privileges.

Lessons Learned

- Anonymous FTP access should be disabled unless explicitly required, and never used to host sensitive files.
- Sudo permissions should follow least privilege — pagers, editors, and similar utilities should never be grantable via sudo without restriction (e.g. using --secure-edit or restricted wrappers).
- Regularly audit 'sudo -l' output against GTFOBins to catch privilege escalation paths before attackers do.

Prepared by Abhishek Dinesh — Cybersecurity Lab Log